

EXPLOITED VULNERABILITY ADVISORY: CVE-2026-53362

Summary

CVE-2026-53362 in Linux Kernel is being actively exploited in the wild. In the Linux kernel, the following vulnerability has been resolved:

ipv6: account for fraggap on the paged allocation path

In `__ip6_append_data()`, when the paged-allocation branch is taken (`MSG_MORE` / `NETIF_F_SG` / large fraglen), `alloclen` and `pagedlen` are computed as

```
alloclen = fragheaderlen + transhdrlen;  
pagedlen = datalen - transhdrlen;
```

`datalen` already includes fraggap (`datalen = length + fraggap`). When fraggap is non-zero, this is not the first skb and `transhdrlen` is zero. The fraggap bytes carried over from the previous skb are copied just past the fragment headers in the new skb's linear area. The linear area is therefore undersized by fraggap bytes while `pagedlen` is overstated by the same amount, and the copy writes past `skb->end` into the trailing `skb_shared_info`.

An unprivileged user can trigger this via a UDPv6 socket using `MSG_MORE` together with `MSG_SPLICE_PAGES`.

The bad accounting was introduced by commit 773ba4fe9104 ("ipv6: avoid partial copy for zc"). Before commit ce650a166335 ("udp6: Fix `__ip6_append_data()`'s handling of `MSG_SPLICE_PAGES`"), the negative copy value caused `-EINVAL` to be returned. That later commit allowed `MSG_SPLICE_PAGES` to proceed in this case, making the corruption triggerable.

The non-paged branch sets `alloclen` to `fraglen`, which already accounts for fraggap because `datalen` does. Bring the paged branch in line by adding fraggap to `alloclen` and subtracting it from `pagedlen`.

After this adjustment, copy no longer collapses to `-fraggap` on the paged path, so remove the stale comment describing that old arithmetic. Since a negative copy is no longer expected for a valid `MSG_SPLICE_PAGES` case, remove the `MSG_SPLICE_PAGES` exception from the negative copy check. CISA requires federal remediation by 2026-08-30; under the CRA, exploitation of an affected product must be reported within 24 hours.

What we know

- **CVE:** CVE-2026-53362
- **Affected:** Linux Kernel
- **Exploitation:** Actively exploited, added to CISA KEV on 2026-08-27

- **Severity:** CVSS 7.8 High, Local-exploitable, no user interaction (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
- **Exploitation likelihood (EPSS):** 1%

Recommended action

Patch CVE-2026-53362 by 2026-08-30. If you cannot patch immediately, apply available vendor mitigations and monitor for exploitation until patched. If you ship an affected product, be ready to file the CRA 24-hour report the moment you find it exploited.

Sources: CISA Known Exploited Vulnerabilities, NIST NVD. Public data; an advisory of active exploitation, not an incident report. Verify applicability to your estate before acting.

